

FA2.7 – SET B

Think, Draw & Secure: Role-Based Access Scenarios

Above-average difficulty
Role-Based Access Control (RBAC)
UI Design & Security

Activity Overview

In this activity, you will analyze more challenging situations involving user roles, permissions, web controls, and access restrictions in machine learning systems, government portals, financial applications, and other information systems.

You will examine what happens when users change roles, access restricted pages, modify requests, or perform actions beyond their permissions.

For each scenario, you must draw the default interface, illustrate the user's action, draw the resulting interface or system state, and explain whether the system's behavior is correct, secure, and user-friendly.

Remember: Hiding a button is not the same as securing an action. A secure system must enforce permissions on the server, even when users manipulate the interface or send requests directly.

Learning Objectives

At the end of this activity, students should be able to:

1. Analyze role-based access control in different types of web applications.
2. Predict how controls and interfaces change based on user roles and permissions.
3. Illustrate default, modified, and restricted-access states.
4. Identify authorization flaws, privilege escalation, and insecure design.

5. Recommend appropriate validation, access-control, and feedback mechanisms.

General Instructions

- Answer all 10 scenarios individually.
- Each scenario is worth 10 points.
- Draw the default state and the resulting state after the specified action.
- Include relevant buttons, dropdowns, labels, messages, status indicators, and access restrictions.
- Identify the user's role, the requested action, and whether the action should be allowed or denied.
- Explain the proper behavior of the system.
- You may draw by hand or use a digital drawing tool.
- Focus on correct system behavior, security, and design—not artistic ability.

Required format for EACH scenario

Scenario Drawing Template	
A. Default State User's role and original interface	B. Action / New State After the user performs the action
Draw the controls visible before the action.	Draw the updated interface, error, or access result.
C. Analysis • What role does the user have? • What action did the user perform? • Should the action be allowed or denied? • What validation or authorization is required? • Is the design secure and user-friendly? Explain.	

Part I. Student Activity

Scenario 1: Machine Learning Platform — Model Approval Workflow

Machine Learning System

The screenshot displays the IBM OpenPages with Watson Machine Learning System interface. At the top, the header shows 'IBM OpenPages with Watson' and navigation links for 'Home' and 'MOD_0000375'. Below the header, a summary bar indicates the 'Model' is 'MOD_0000375', the 'Model Status' is 'Awaiting Approval', and the 'Final Tier' is visible. An 'Actions' button is present on the right. The main content area is divided into two sections. The left section, titled 'Metrics', contains a search bar and two buttons: 'Add New Metric' and 'Associate Existing Metrics'. Below these is a table of metrics:

Metric Name	Description	Breach Status	Value Date
MET_0610	Watson OpenScale fairness metric for 'Age'	Green	11/4/2020
MET_0611	Watson OpenScale fairness metric for 'Sex'	Green	11/4/2020
MET_0612	Watson OpenScale quality metric for 'area_under_roc'	Red	11/4/2020
MET_0613	Watson OpenScale quality metric for 'area_under_pr'	Red	11/4/2020
MET_0614	Watson OpenScale quality metric for 'accuracy'	Red	11/4/2020

The right section, titled 'Model Approval', shows the current stage as 'Approval (Model Deployment Approval)' with a due date of '11/14/2020'. It includes a 'Model Approval' section with the text 'Please Approve the Model for Deployment' and 'OR'. Below this is a 'Select an action to validate' dropdown menu, a progress bar, and a summary of '4 items require attention'. At the bottom, it lists 'All Key Items (6)' and shows a status 'Model Non Model'.

A machine learning platform has three roles:

- Data Scientist – can train and submit models for review.
- Model Reviewer – can review and approve submitted models.
- System Administrator – can manage user accounts and system settings.

A Data Scientist has trained a model and sees the status Pending Review. The Data Scientist manually changes the URL from /models/104 to /models/104/approve and attempts to approve their own model.

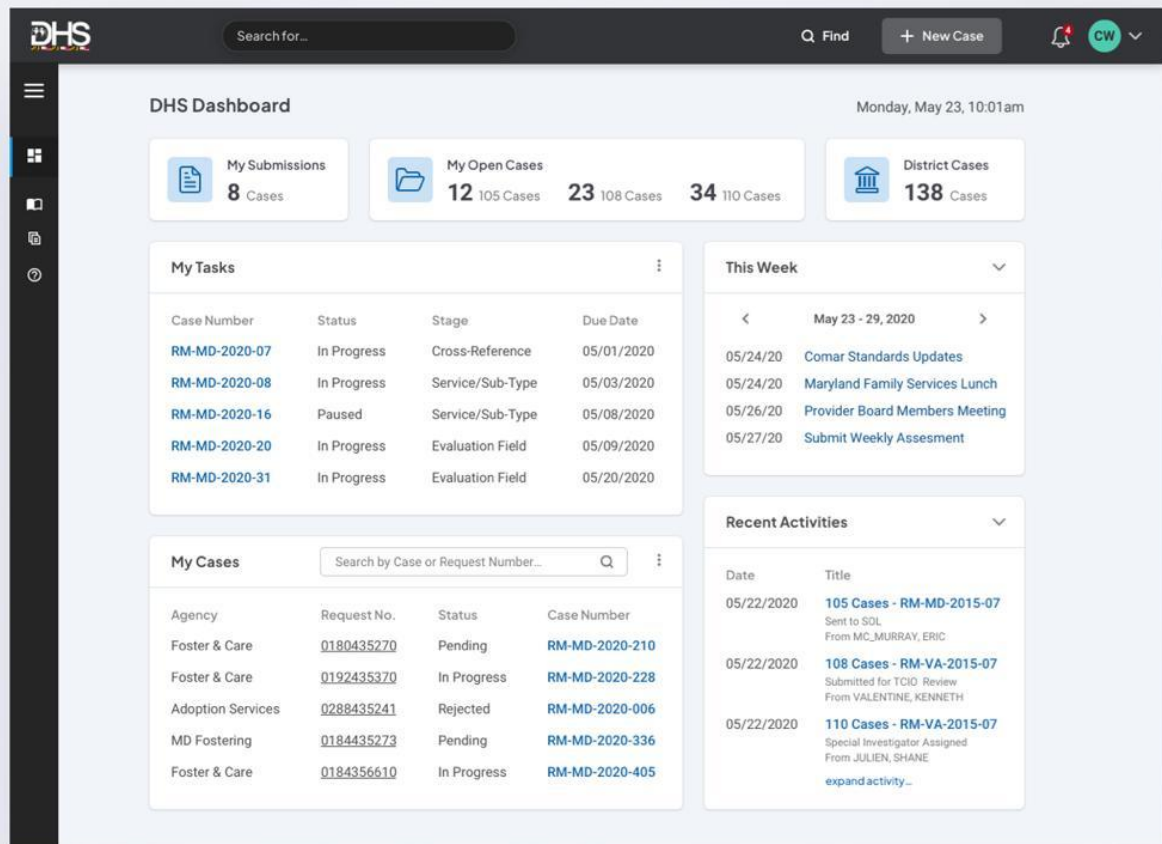
Your tasks:

1. Draw the model dashboard as seen by the Data Scientist before the action.

2. Draw the new state after the Data Scientist attempts to approve the model.
3. Show which controls should be visible or unavailable to the Data Scientist.
4. Explain how the system should prevent a user from approving their own model without reviewer permission.

Scenario 2: Government Benefits Portal — Unauthorized Record Access

Government System



A government benefits system has the following roles:

- Applicant – can view and update their own application.
- Case Officer – can view and process assigned applications.

- Supervisor – can review and reassign cases.

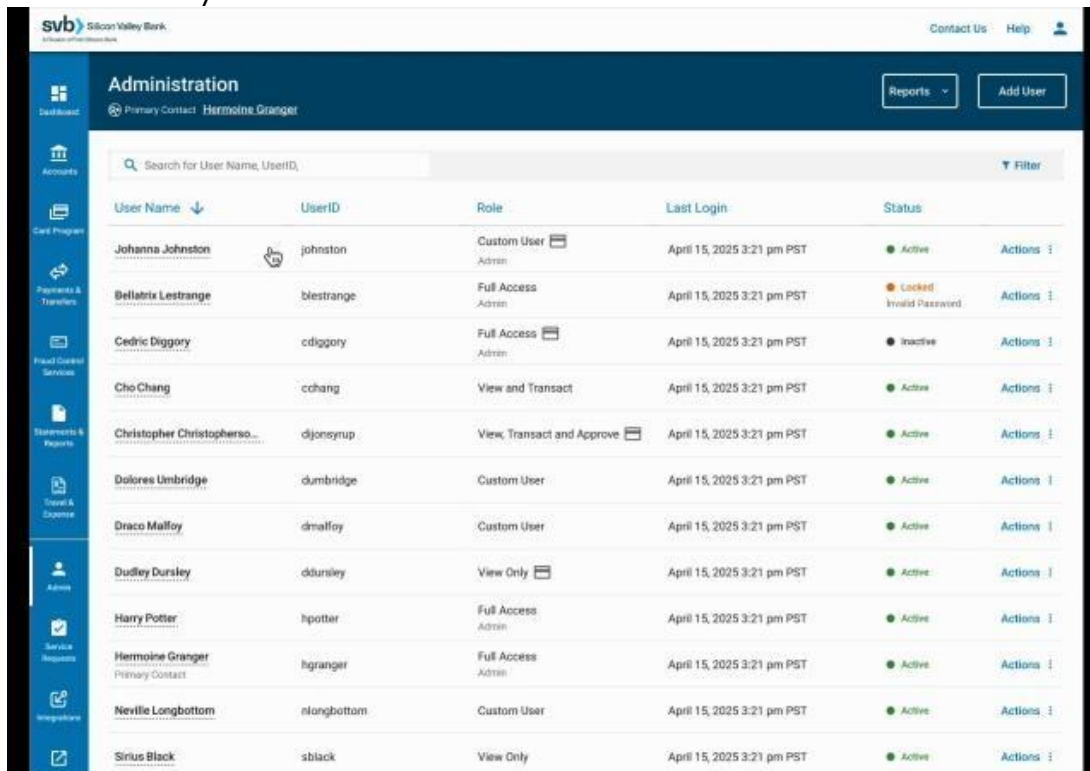
An Applicant is logged in and can view their own application, APP-2026-015. The Applicant changes the application ID in the URL to APP-2026-016, which belongs to another citizen.

Your tasks:

1. Draw the Applicant's original application page.
2. Draw the new state after the Applicant changes the application ID.
3. Show the correct response if the Applicant is not authorized to view the other record.
4. Explain how the system should verify record ownership and prevent unauthorized access.

Scenario 3: Banking System — Role Switching and Privilege Escalation

Financial System



The screenshot shows the 'Administration' page of the svb Silicon Valley Bank system. The page has a dark blue header with the bank logo and navigation links. A sidebar on the left contains icons for various system functions. The main content area displays a table of users with columns for User Name, UserID, Role, Last Login, and Status. The table lists several users, including Johann Johnson, Bellatrix Lestrage, Cedric Diggory, Cho Chang, Christopher Christopher, Dolores Umbridge, Draco Malfoy, Dudley Dursley, Harry Potter, Hermione Granger, Neville Longbottom, and Sirius Black. Each user entry includes an 'Actions' link.

User Name	UserID	Role	Last Login	Status
Johanna Johnston	johnston	Custom User Admin	April 15, 2025 3:21 pm PST	Active
Bellatrix Lestrage	blestrange	Full Access Admin	April 15, 2025 3:21 pm PST	Locked Invalid Password
Cedric Diggory	cdiggory	Full Access Admin	April 15, 2025 3:21 pm PST	Inactive
Cho Chang	cchang	View and Transact	April 15, 2025 3:21 pm PST	Active
Christopher Christopher...	djonesguy	View, Transact and Approve	April 15, 2025 3:21 pm PST	Active
Dolores Umbridge	dumbridge	Custom User	April 15, 2025 3:21 pm PST	Active
Draco Malfoy	dmalfroy	Custom User	April 15, 2025 3:21 pm PST	Active
Dudley Dursley	ddursley	View Only	April 15, 2025 3:21 pm PST	Active
Harry Potter	hpotter	Full Access Admin	April 15, 2025 3:21 pm PST	Active
Hermione Granger Primary Contact	hgranger	Full Access Admin	April 15, 2025 3:21 pm PST	Active
Neville Longbottom	nlongbottom	Custom User	April 15, 2025 3:21 pm PST	Active
Sirius Black	sblack	View Only	April 15, 2025 3:21 pm PST	Active

A bank's internal web system has these roles:

- Customer Service Agent – can view customer profiles and assist with account inquiries.
- Branch Manager – can approve certain account changes.
- System Administrator – can manage employee accounts and roles.

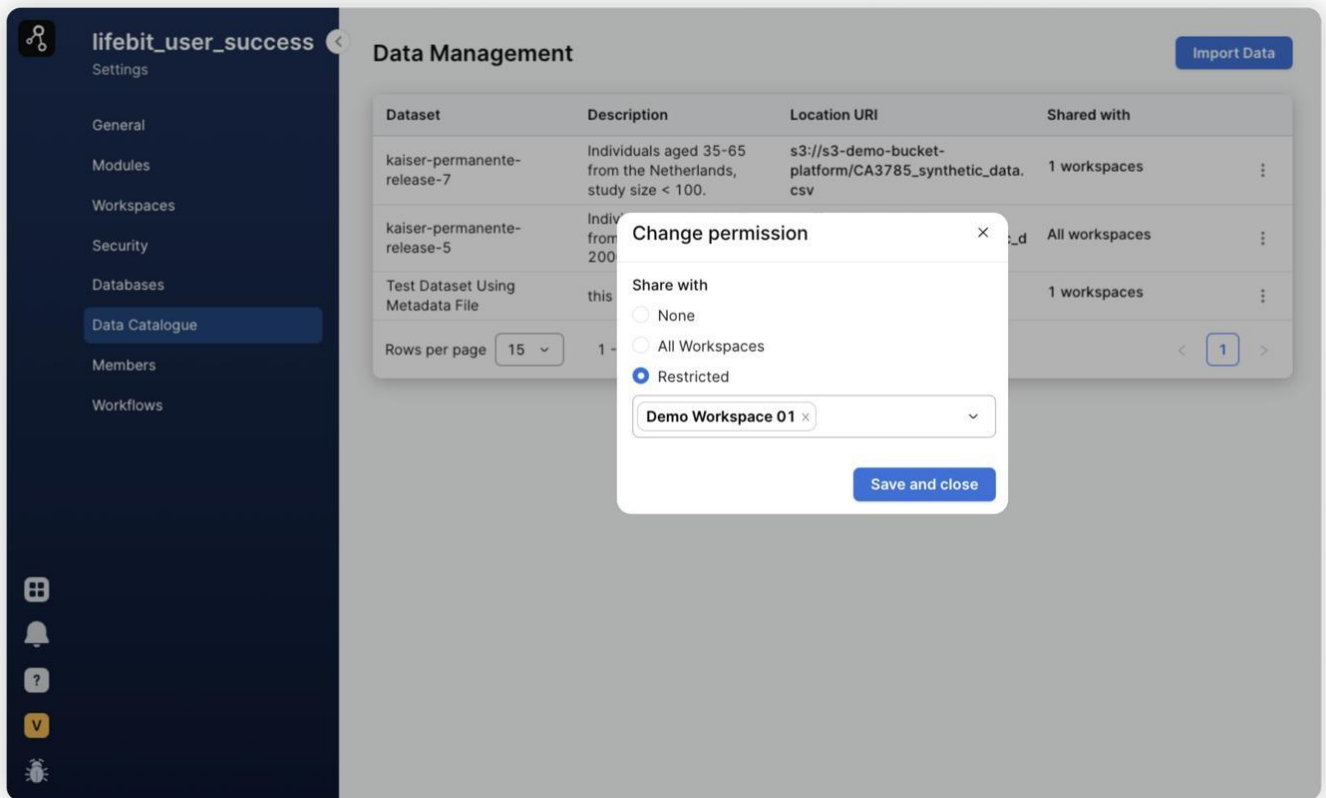
A Customer Service Agent discovers a role dropdown in their profile. The Agent changes the displayed role from Customer Service Agent to System Administrator and clicks Save.

Your tasks:

1. Draw the Agent's default profile page.
2. Draw the new state after the Agent attempts to change their role.
3. Show the correct system response and role displayed after the attempt.
4. Explain why users should not be allowed to grant themselves privileged roles through a profile control.

Scenario 4: Machine Learning System — Sensitive Dataset Access

Machine Learning / Data Privacy



A machine learning platform stores both public datasets and restricted datasets containing sensitive customer information.

Its roles include:

- ML Researcher – can access approved datasets.
- Data Privacy Officer – can approve access to restricted datasets.
- Platform Administrator – can manage system configurations.

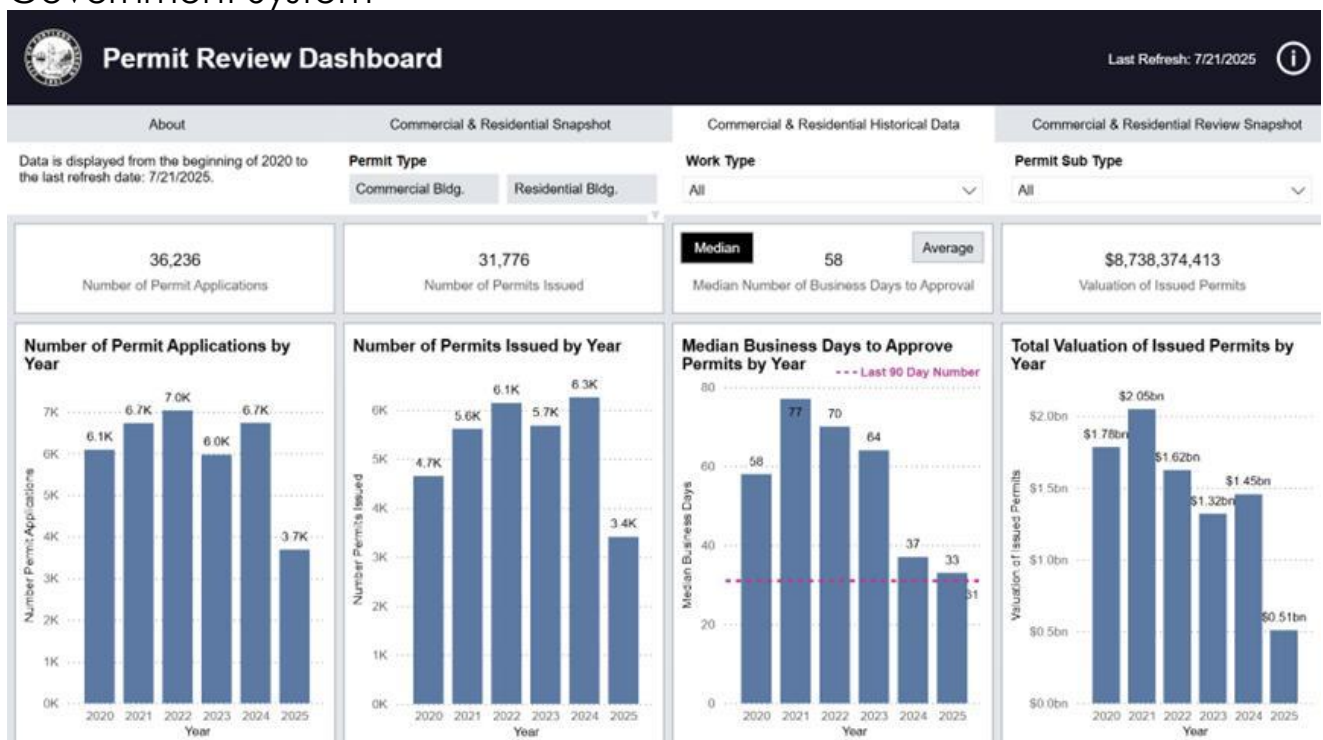
An ML Researcher can see a restricted dataset named Customer_Risk_2026 in the dataset catalog but does not have permission to download it. The Researcher clicks Download and then tries a direct download URL.

Your tasks:

1. Draw the dataset catalog as seen by the Researcher.
2. Draw the new state after the Researcher attempts to download the restricted dataset.
3. Show the appropriate control behavior and access-denied feedback.
4. Explain how the system should handle sensitive datasets and why hiding the Download button alone is insufficient.

Scenario 5: Government Licensing System — Separation of Duties

Government System



A city government's business permit system has the following roles:

- Encoder – can create and edit permit applications.
- Evaluator – can review documents and recommend approval.
- Approving Officer – can approve or reject evaluated applications.

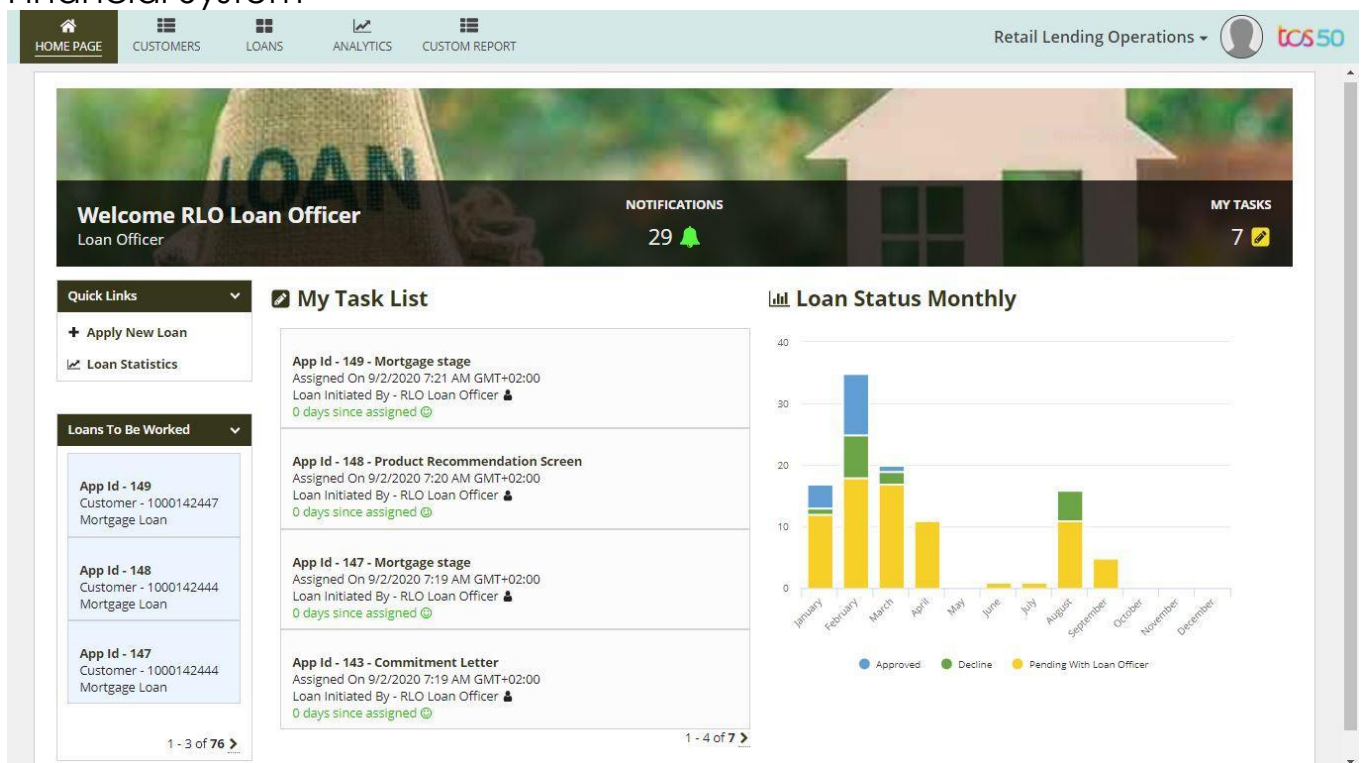
An Encoder completes a business permit application and attempts to click an Approve button by modifying the page's HTML using browser developer tools.

Your tasks:

1. Draw the Encoder's default application interface.
2. Draw the new state after the Encoder attempts to approve the permit.
3. Show the correct status of the application and any feedback.
4. Explain how role permissions and separation of duties should be implemented.

Scenario 6: Financial Loan System — Approval Limit

Financial System



A financial institution has a loan approval system:

- Loan Officer – can approve loans up to ₱100,000.
- Senior Loan Officer – can approve loans up to ₱500,000.

- Branch Manager – can approve loans above ₱500,000, subject to policy.

A Loan Officer reviews a loan application for ₱350,000. The system displays an Approve button, but the Loan Officer is not authorized to approve an amount above ₱100,000.

Your tasks:

1. Draw the Loan Officer's default loan review page.
2. Draw the new state after the Loan Officer clicks Approve.
3. Show the correct approval status and system feedback.
4. Explain why authorization must consider both the user's role and the loan amount.

Scenario 7: Machine Learning System — Role Change During an Active Session

Machine Learning / Session Management

The screenshot displays the 'Permissions' section of the Ahana interface. It features a navigation bar with 'Home', 'Clusters', 'Data', 'Workspaces', and 'Integrations'. The 'Permissions' page has three tabs: 'Cluster permissions', 'Data permissions', and 'Workspace permissions'. The 'Cluster permissions' tab is active, showing a table with columns for Name, Create, Query, Resize, and Terminate. Below it, the 'Data permissions' tab is also visible, showing columns for Name, Add source, and Integrate with Ranger. Both tables list users: William Ford (You), Betty Cooper, Peter Horton, and Randall Boone. Checkmarks indicate granted permissions, while empty boxes indicate denied permissions.

Name	Create	Query	Resize	Terminate
William Ford (You)	☒	☒	☒	☒
Betty Cooper	☒	☒	☐	☐
Peter Horton	☒	☐	☒	☐
Randall Boone	☐	☒	☐	☐

Name	Add source	Integrate with Ranger
William Ford (You)	☒	☒
Betty Cooper	☐	☒
Peter Horton	☒	☒

A machine learning platform has two roles:

- ML Analyst – can view model performance and reports.
- ML Administrator – can manage models, users, and deployment settings.

An ML Administrator is logged in on two browser tabs. In Tab 1, the administrator changes the user's role to ML Analyst. In Tab 2, the user still has the previously opened Model Deployment page, including the Deploy button.

Your tasks:

1. Draw the Model Deployment page in Tab 2 before the role change.
2. Draw the new state after the role is changed in Tab 1 and the user attempts to deploy a model in Tab 2.
3. Show how the system should respond to the outdated session or page.
4. Explain how the system should enforce updated permissions across multiple tabs and requests.

Scenario 8: Government Procurement System — Conflicting Roles

Government / Procurement System

Aumentar el contraste

UTC -5 18:23:39
Agencia Nacional...

Procesos Contratos Proveedores Menú Ir a

Buscar...

Escritorio → Menú → Procesos de la Entidad Estatal → Expediente

Id de página: 10005217 Ayuda

Volver

Opciones

Mensaje enviado

Proceso : Obras de adecuación y mejoramiento de colegios ... (id.CO1.BDOS.42908) EN EVALUACIÓN Fases

Licitación pública | Presentación de oferta
LP-001.-2017 copia (Presentación de oferta) En evaluación Ver pliegos
Valor estimado 819.000.000 COP | Clasificación de objetos Obra
Unidad de contratación Grupo Contratos

PROVEEDORES

Interesados 4

Competidores 3

Contratar las obras de adecuación, mejoramiento y complementarias que permitan implementar el proyecto "Jornada extendida de 40 horas semanales" en diferentes colegios de las localidades de la ciudad.

(Zona horaria (UTC-05:00) Bogotá, Lima, Quito)
Fecha de presentación de ofertas 05/04/2017 05:03 PM - Fecha de publicación 04/04/2017 03:50 PM
Apertura 05/04/2017 05:04 PM

Ver más

LÍNEA DE TIEMPO

✓ Fecha de publicación del proceso	✓ Plazo para presentar observaciones al Proyecto de Pliego de Condiciones	✓ Respuesta a las observaciones al Pliego de Condiciones	Presentación de ofertas	✓ Apertura de ofertas	✓ Publicación Acto Administrativo de adjudicación o de Declaratoria de Desierto
04/04/2017	05/04/2017	05/04/2017	05/04/2017	05/04/2017	05/04/2017

Selección de ofertas (borrador)

Presentación de oferta

LISTA DE OFERTAS (3) + Abrir Panel Opciones

Referencia de oferta	Entidad	Evaluación	Presentada	Oferta
Oferta LP-001.-2017	Union Temporal F&D	Oferta en evaluación	05/04/2017 03:40 PM	716.443.200 COP
Oferta LP-001.-2017	Rojas Cifuentes SAS	Oferta en evaluación	05/04/2017 03:33 PM	763.725.000 COP
Oferta LP-001.-2017	H&H Asociados	Oferta en evaluación	05/04/2017 03:29 PM	809.300.000 COP

EVALUACIÓN ECONÓMICA + Nuevo Opciones

EVALUACIÓN + Nuevo Opciones

INFORMES PROCESO DE SELECCIÓN + Crear Opciones

OBSERVACIONES A LOS DOCUMENTOS DEL PROCESO Contestar

RE: Observación a los criterios de Evaluación
Andrea Carolina López
05/04/2017 10:11 AM

Observación a los criterios de Evaluación
H&H Asociados 04/04/2017 05:22 PM

Ver más

MENSAJES Crear

RE: Subsanan Documento
H&H Asociados
05/04/2017 06:33 PM

Subsanar Documento
Agencia Nacional de ...
05/04/2017 06:23 PM

Ver más

A government procurement platform has the following roles:

- Bidding Officer – can manage supplier bids.
- Evaluator – can evaluate submitted bids.
- Approving Officer – can approve the procurement recommendation.

An employee has accidentally been assigned both the Evaluator and Approving Officer roles for the same procurement project. The employee evaluates a bid and attempts to approve the same recommendation.

Your tasks:

1. Draw the employee's procurement dashboard before the approval attempt.
2. Draw the new state after the employee attempts to approve the recommendation they evaluated.
3. Show the appropriate warning, restriction, or status.
4. Explain why some systems should prevent conflicting role combinations and enforce separation of duties.

Scenario 9: Digital Wallet — Transaction-Specific Authorization

Financial Technology

The screenshot displays the Janva digital wallet interface. On the left is a dark sidebar with navigation options: Janva Organisation, Balances, Expenses, Bills, Payment Overview, Reports, Settings (with sub-items: User Management, Spend Approvals, **Transfer Approvals**, Connections, Plan & Billing), Janva SG, Janva, Dashboard, Wallet, Transfers, Cards, Payments, Rewards, Developer, and Security. The main content area has tabs for 'Workflows' and 'Change requests'. A notification banner at the top states: '2 accounts have changes pending your approval. The updated workflows will take effect for all new transfers only upon owner approval.' Below this, the 'Transfer approval workflows' section is visible. It contains two workflow cards. The first card, titled '5 Accounts', lists five accounts: Thinkley Europe GmbH (Germany), Thinkley France SAS, Thinkley London, Thinkley S.L., and Thinkley Operations. The second card, titled 'Workflow EUR · 3 amount ranges', details three approval thresholds: 'Less than 5,000 EUR' (Any 2 can approve: Celine Dubois, Liam Jones, Oliver Harris, Sophie Dubois), 'From 5,000 to 100,000 EUR' (2 must approve: Celine Dubois, Liam Jones), and 'Greater than or equal to 100,000 EUR' (First, 2 must approve: Anthony Moreau, Finn O'Connell; Then, any 2 can approve: Finn O'Connell, Jane Tan, Oliver Harris, Sophie Dubois; Then, all 3 must approve: Liam O'Connor, Hiroshi Tanaka, James Wang). A third card, titled 'Account', shows a workflow for 'Thinkley Europe GmbH (Germany)' with a single range: 'For transfers of any amount' (Any 2 can approve: Sophie Dubois, Oliver Harris, Liam Jones). An 'Edit workflows' button is located in the top right of the workflow section.

A company digital wallet has these roles:

- Cashier – can prepare transfers but cannot release them.
- Finance Manager – can approve transfers up to ₱50,000.
- Finance Director – can approve transfers above ₱50,000.

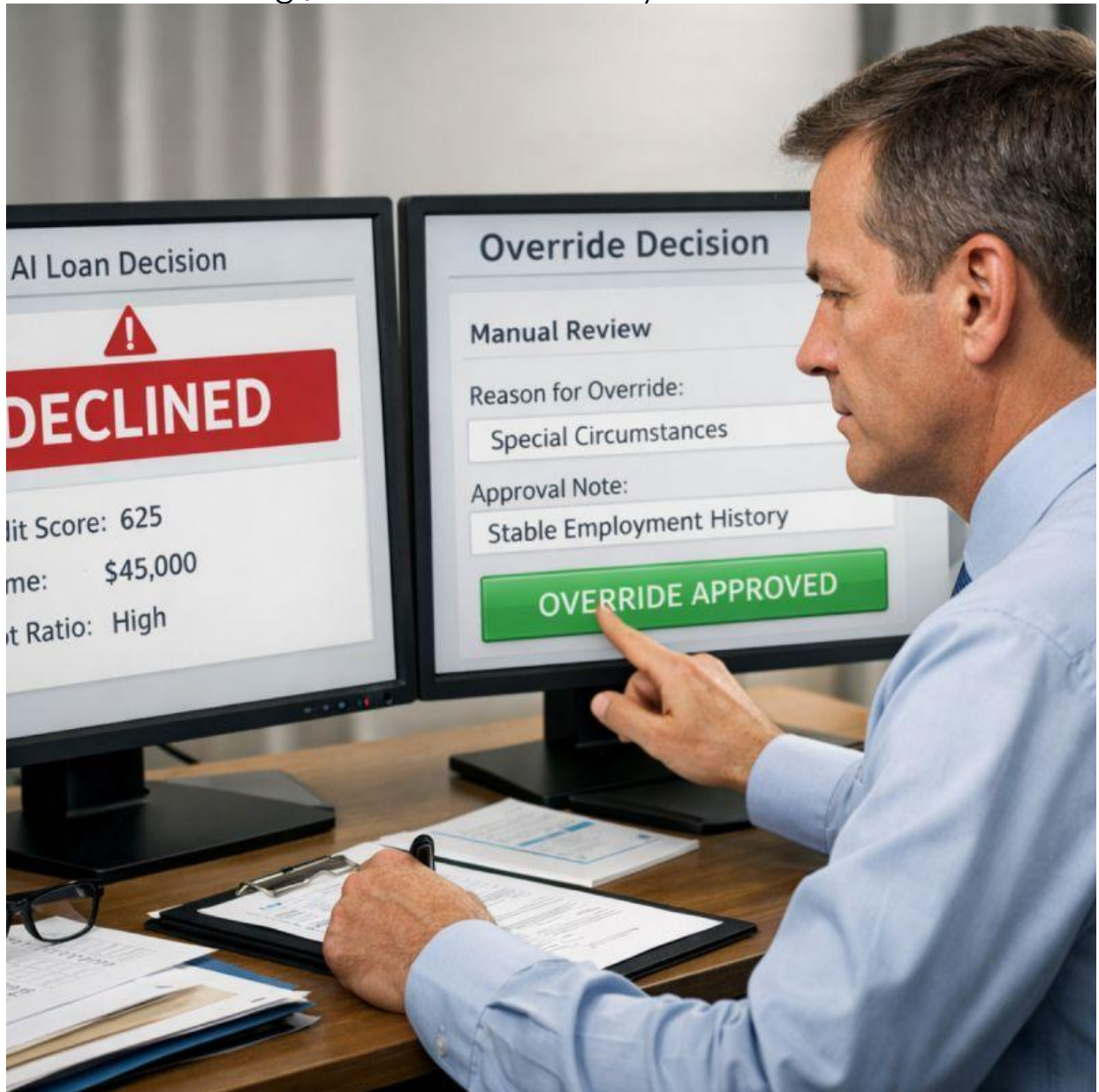
A Cashier prepares a ₱40,000 transfer. The system displays the transaction as Pending Approval. The Cashier copies the transaction ID and attempts to approve it through a direct API request.

Your tasks:

1. Draw the Cashier's transfer dashboard before the approval attempt.
2. Draw the new state after the Cashier attempts to approve the transfer.
3. Show the correct transaction status and feedback.
4. Explain why knowing a transaction ID does not grant permission to approve it.

Scenario 10: AI-Powered Credit Scoring System — Model Override

Machine Learning / Financial Decision System



A financial institution uses an AI model to assess loan applications. The system has these roles:

- Credit Analyst – can view model predictions and add review notes.
- Senior Credit Reviewer – can review flagged predictions and recommend a decision.

- Credit Manager – can authorize decisions according to institutional policy.

An AI model flags a loan application as High Risk. A Credit Analyst disagrees with the prediction and changes a hidden form value from High Risk to Low Risk, then attempts to approve the loan.

Your tasks:

1. Draw the Credit Analyst's default AI assessment page.
2. Draw the new state after the Analyst modifies the hidden value and attempts to approve the loan.
3. Show the proper system response, including the prediction, review status, and access restriction.
4. Explain how the system should protect model outputs, record human overrides, and enforce decision-making permissions.

Part II. Overall Assessment and Scoring Rubric

Each scenario is worth 10 points. Total score: 100 points.

Assessment Criteria	Points
Correct default interface and role-specific controls	2
Correct new state after the user's action	2
Proper behavior, validation, and authorization	2
Security analysis and appropriate solution	3
Clear, labeled, understandable drawing	1
Total per scenario	10

Final Submission Requirements

- Submit legal white paper with answer to assigned scenario
- Include default and new-state drawings for every scenario.
- Include a brief explanation of the expected system behavior.

- Clearly identify the role, attempted action, and access decision.

Final Reflection

After completing the scenariip, answer these three questions:

1. Why is hiding a button not enough to protect a restricted action?
2. What is the difference between authentication and authorization?
3. How can a web application enforce role changes and permissions when users have multiple tabs or devices open?

Key principle: A secure web application does not trust a user's interface, hidden fields, URL, or submitted role value. It verifies the user's permissions on the server whenever a protected action or resource is requested.